📄 2. INFORME TÉCNICO DETALLADO (Para Equipo de TI / SOC)

Fecha de generación: 07 de noviembre de 2026
Clasificación: RESTRINGIDO
Elaborado por: Analista SOC Nivel 2

📊 Estadísticas del Análisis

- Total de eventos analizados: 715
- Eventos sospechosos/críticos detectados: 42
- Direcciones IP únicas involucradas: 18
- Período de análisis: 2026-10-23 07:46:07 a 2026-10-23 13:44:06

🎯 Indicadores de Compromiso (IoCs)

Tipo	Indicador	Contexto
IP Externa	198.51.100.77	Origen de ataque RDP y fuerza bruta contra APP-SRV01
IP Externa	203.0.113.88	Destino de exfiltración de datos vía PowerShell (Puerto 443)
IP Externa	198.51.100.88	Destino de exfiltración masiva vía Proxy HTTPS (Puerto 443)
IP Externa	192.0.2.91	Origen de ataques de inyección de comandos web en WEB-01
Cuentas	CORP\admin, CORP\helpdesk, CORP\rrojas	Cuentas comprometidas o abusadas

Archivos	C:\ProgramData\wuhelper.exe	Binario malicioso instalado como servicio
Archivos	C:\ProgramData\updatecheck.ps1	Script de persistencia en tarea programada

⏱️ Cronología del Ataque (Kill Chain)

1. Reconocimiento y Fuerza Bruta (08:25 - 08:34):
   La IP 203.0.113.74 realiza un ataque de password spraying contra el DC-01 probando múltiples usuarios (jlopez, aperez, helpdesk, etc.). (Eventos: EVT-00057 a EVT-00111).
2. Compromiso Inicial (09:02 - 09:06):
   La IP 198.51.100.77 fuerza el acceso RDP (LogonType=10) de CORP\admin en APP-SRV01. El login es exitoso a las 09:06:00 (Evento EVT-00188, Severidad: Alta).
3. Ejecución y Movimiento Lateral (09:09 - 09:17):
   - Se ejecuta PowerShell con comando codificado (EVT-00198).
   - Script block detectado: Get-LocalGroupMember Administrators; Get-SmbShare (EVT-00207).
   - El atacante mapea la red: net.exe view \\FS-SRV01 (EVT-00214).
   - Inicio de sesión exitoso en FS-SRV01 como CORP\admin (EVT-00225).
4. Recolección y Exfiltración de Datos (09:17 - 09:21):
   - Acceso detallado a \\FS-SRV01\Finance\Budget2027.xlsx (EVT-00231).
   - Compresión de datos: tar.exe -a -c -f C:\Temp\finance.zip C:\Temp\reports (EVT-00232).
   - Conexión saliente permitida a 203.0.113.88:443 iniciada por powershell.exe (EVT-00235).
5. Exfiltración Secundaria (Posible Amenaza Interna) (10:42 - 10:49):
   El usuario CORP\rrojas en WS-018 comprime archivos legales (7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx, EVT-00428) y realiza múltiples subidas HTTPS POST masivas (totalizando >100 MB) a 198.51.100.88 (EVT-00430 a EVT-00461).
6. Anti-Forensis (09:42):
   Ejecución de vssadmin.exe delete shadows /all /quiet en WS-023 bajo la cuenta CORP\backupsvc (EVT-00314), buscando eliminar puntos de restauración.
7. Persistencia (11:37 - 11:40):
   - Creación de tarea programada maliciosa: \Microsoft\Windows\UpdateCheck ejecutando updatecheck.ps1 (EVT-00523).
   - Instalación de servicio sospechoso: WinUpdateHelper apuntando a C:\ProgramData\wuhelper.exe (EVT-00524, EVT-00528).
8. Ataque al Servidor Web (12:10 - 12:15):
   La IP 192.0.2.91 explota una posible web shell en WEB-01 (/uploads/test.aspx?cmd=whoami), logrando ejecutar cmd.exe /c whoami bajo el contexto de IIS APPPOOL\DefaultAppPool (EVT-00599).

📋 Hallazgos Detallados por Severidad

🔴 RIESGO ALTO

- Compromiso de APP-SRV01: Inicio de sesión RDP exitoso de atacante externo seguido de ejecución de PowerShell ofensivo y exfiltración. (Eventos: EVT-00188, EVT-00198, EVT-00235).
- Acceso a Datos Sensibles: Lectura confirmada de archivos financieros y legales por actores no autorizados o cuentas comprometidas. (Eventos: EVT-00231, EVT-00428).

🟡 RIESGO MEDIO

- Fuerza Bruta RDP: Múltiples intentos fallidos de inicio de sesión contra la cuenta CORP\admin desde 198.51.100.77 previos al éxito. (Eventos: EVT-00174 a EVT-00180).
- Movimiento Lateral: Uso de net.exe view para enumerar recursos de red tras el compromiso inicial. (Evento: EVT-00214).

🟢 RIESGO BAJO / INFORMATIVO

- Password Spraying en DC: Intentos fallidos distribuidos contra múltiples cuentas en el Controlador de Dominio. Requiere revisión de políticas de bloqueo, pero no fue el vector de éxito principal. (Eventos: EVT-00057 a EVT-00111).

🛠️ Recomendaciones Técnicas de Remediación

1. Aislamiento Inmediato: Desconectar de la red APP-SRV01, WEB-01 y WS-018 para preservar evidencia en memoria y disco.
2. Caza de Amenazas (Threat Hunting): Buscar en toda la red la presencia del archivo C:\ProgramData\wuhelper.exe y la tarea programada UpdateCheck.
3. Revisión de Firewall/Proxy: Bloquear de forma permanente las IPs 198.51.100.77, 203.0.113.88, 198.51.100.88 y 192.0.2.91. Investigar por qué el proxy permitió subidas POST tan grandes (bytes_out > 10MB) a dominios no categorizados.
4. Auditoría de Cuentas: Deshabilitar temporalmente las cuentas CORP\admin, CORP\helpdesk y CORP\rrojas hasta completar la investigación forense.
5. Revisión de Backups: Verificar la integridad de las copias de seguridad, ya que se ejecutó un comando para borrar shadow copies (vssadmin).